

ChillFi

Complete Project Report

Master QA · Fixes · New features · Delhivery staging · Production deployment · Readiness

25 September 2026 · Mobile app (Flutter) · Website (React) · Admin panel · Backend (Node/Express + PostgreSQL)

438/463 test cases passed	0 failing test cases	124 defects found & fixed
11 critical issues fixed	48/48 Delhivery staging lifecycle	510 responsive checks, 0 issues

Status in one line: the code is production-ready and live on chillfi.in. Real customers can be served once the owner switches PhonePe and Delhivery to live credentials from the admin panel (Settings › Go-Live checklist). Until then the site safely takes Cash on Delivery orders only.

Contents

1. Executive summary
2. Scope and method
3. Test results by area
4. Security findings and fixes
5. Money, payments and orders
6. Delhivery shipping (staging end-to-end)
7. Admin › app / website synchronisation
8. Responsive and usability audit
9. New features built
10. Production deployment log
11. Production readiness today (Go-Live checklist)
12. Owner action list
13. Operations: backups, monitoring, server
14. Remaining limitations
15. Appendix A — Screenshots
16. Appendix B — Complete defect register

1. Executive summary

The whole ChillFi system was inventoried and tested against three project-specific QA checklists (463 test cases). **438 pass, 0 fail, 10 blocked** (each needs a credential or an action only the owner can take) and 15 not applicable. No case is left untested.

Testing found **124 defects** — 11 critical, 46 high, 41 medium, 26 low. **All are fixed, re-tested and deployed.** The most serious were a price exploit (negative cart quantities), admin settings exposing stored credentials to the browser, a coupon bypass, test-payment shortcuts reachable on the live server, an unused password login that gave single-factor access to the admin account, and abandoned payments holding stock forever.

The core business flow was proven end-to-end against **real Delhivery staging**: product › cart › checkout › order › shipment (AWB) › tracking events › customer notifications (in-app + push) › Delivered, with the app, website, admin and database all showing the same final state.

Beyond fixes, the project gained: GST-inclusive pricing, GST tax invoices, email and SMS notification channels, admin new-order and low-stock alerts, a Go-Live checklist in the admin, abandoned-payment expiry with automatic refunds for late payments, contact details editable from the admin, nightly database backups, a health endpoint for uptime monitoring, a Node 22 server upgrade and auto-restart on reboot.

Verdict. Production-ready from a code, security and testing standpoint. **Before taking real online payments and live shipments** the owner must, from the admin panel: (1) enter live PhonePe keys, (2) enter the live Delhivery token and pickup location, (3) confirm COD with Delhivery, (4) publish app v1.0.3 and turn on force update, (5) enter the real GSTIN and contact details. Recommended: uptime monitor, SMTP email, off-server backup copy.

2. Scope and method

Component	Technology	What was covered
Mobile app	Flutter (Android), v1.0.3+4	Every screen: onboarding, OTP login/sign-up, home, search, listing, product, cart, checkout, payment, orders, tracking, wishlist, profile, help, settings, permissions, push
Website	React + Vite + TypeScript	All customer pages incl. account, orders, tracking, checkout, policies; 30 pages × 17 screen widths
Admin panel	React (same site, /admin)	Dashboard, products, orders, refunds, users, categories, brands, reviews, messages, notifications, analytics, banners, coupons, shipping rules, settings, API keys
Backend	Node/Express, PostgreSQL 15	Every API used by the three clients, payments (PhonePe), shipping (Delhivery), notifications, security
Integrations	Delhivery staging, PhonePe UAT, Firebase	Real staging shipments, sandbox payments, real OTP (test number) and FCM push

Method

- Each defect followed **find › fix › re-test › regression › record**; nothing marked PASS without evidence (screenshots, API output or logs).
- Automated browser suites (Playwright, 17 suites) for website and admin; Android emulator driving for the app; API-level lifecycle scripts for Delhivery and payments.
- Production was only touched with explicit owner approval: two read-only checks, one data correction (ratings), five deployments and server maintenance.
- Delhivery was used in **staging only**; no real shipment was created and no real money moved.

3. Test results by area

Area	Total	Pass	Fail	Blocked	N/A	Pass rate
Mobile app	231	212	0	4	15	98.1%
Website	136	132	0	4	0	97.1%
Admin panel	96	94	0	2	0	97.9%
All	463	438	0	10	15	97.8%

Blocked cases — all waiting on an owner credential or action

Area	Case	What it needs
Mobile app	APP-23-01 "I've Completed Payment"	A completed PhonePe sandbox card payment (owner enters test card)
Mobile app	APP-23-04 Failed payment	PhonePe sandbox failure flow (owner)
Mobile app	APP-24-04 Failed: reason & retry	PhonePe sandbox failure flow (owner)
Mobile app	APP-31-04 Avatar upload	Cloudinary keys (local)
Website	WEB-07-03 Send OTP	Website reCAPTCHA — check once by hand
Website	WEB-07-04 OTP boxes	Website reCAPTCHA — check once by hand
Website	WEB-07-05 Verify & login	Website reCAPTCHA — check once by hand
Website	WEB-09-08 Place online (test payment)	Completed sandbox payment (owner)
Admin panel	ADM-03-09 Image upload	Cloudinary keys on the local test setup (production has keys)
Admin panel	ADM-13-03 Promo banner CRUD + upload	Cloudinary keys (local)

Regression (final run, after all fixes)

Suite / check	Result
Website suites (browse, listing, product, cart, checkout, account, addresses, login, maintenance, serviceability)	107/107
Admin suites A–F (products, orders, refunds, users, catalogue, content, coupons, shipping rules, settings, security)	96/100 — 2 need Cloudinary keys, 1 harness limitation, 1 superseded check
Delhivery staging lifecycle (API, real staging)	48/48
Payment expiry / late-payment refund test	12/12
Responsive audit (30 pages × 17 widths, 320–1920 px)	510 checks · 0 overflow · 0 JS errors
Tap audit (every interactive element reachable)	2,755 elements · 0 blocked
Flutter analyzer	clean (2 pre-existing lint notes)

4. Security findings and fixes

All fixed and deployed to production.

Severity	Finding	Fix
Critical	Cart accepted negative / zero / fractional / huge quantities: a negative line cut the order total (pay ₹1,000 for a ₹5,000 item) and increased stock.	Integer 1...stock enforced on cart add/update; order creation refuses non-positive quantities. Production check: never exploited.
Critical	Saving Admin › Settings returned every stored credential (Delhivery / PhonePe secrets) to the browser.	Credential keys filtered from every settings response; credentials only via masked API-keys screen.
Critical	Coupons not re-validated at order time (expiry, minimum order, per-user use).	Full re-validation inside order creation, with row locks on usage limits.
Critical	Payment test shortcuts could mark orders paid when the server was not strictly "development".	Require explicit development flag; sandbox payments can never mark orders paid on production.
High	Unused password-login route allowed single-factor admin sign-in; password reset open.	Password sign-in/reset disabled; admin sign-in is phone OTP only.
High	Production was running PhonePe in sandbox mode — a sandbox "payment" could have been accepted.	Server refuses online orders/payments until PhonePe is live; clients show COD only.
High	Any token-refresh hiccup (offline, rate limit) signed users out; concurrent refreshes raced.	Single-flight refresh; sign out only when the server rejects the session.
High	Logout left cart/wishlist of the previous user on shared devices; staff role default too permissive.	State cleared on logout; staff role checks tightened; staff blocked from admin-only pages.
Medium	Raw technical errors (SQL, provider messages) could reach customers.	Friendly errors everywhere, internal detail logged with a reference id.

Verified safeguards

- Credentials masked in the admin and encrypted at rest; webhook secret compared in constant time.
- Rate limit 200 requests/min per real client IP in production (proxy-aware).
- Admin/staff sign-ins recorded (time, IP, device); admin panel signs out after 30 minutes idle.
- HTTPS enforced by the web server (HTTP › HTTPS redirect, valid Let's Encrypt certificate, auto-renewing).

5. Money, payments and orders

- **GST-inclusive pricing** (owner decision): the displayed price is the price paid. GST is shown as an "Includes GST" line and stored for invoices. Verified: shown total = charged total on website and app (e.g. ₹999 item › ₹999; 20% coupon › ₹799.20).
- **Abandoned online payments** auto-cancel after 2 hours — only when PhonePe confirms the payment did not complete; stock and coupon released; customer informed. If PhonePe cannot be reached, nothing is cancelled.
- **Late payment on a cancelled order** automatically opens a full refund request and tells the customer (it used to send "Order confirmed" and keep the money).
- **Auto-refund** request whenever a paid order is cancelled; Refunds admin page fixed (it never loaded).
- **Revenue** uses one definition everywhere (paid and not cancelled); analytics stale-response race fixed.
- **Orders keep their delivery address** (snapshot at order time) — editing or deleting an address no longer changes past orders or pending shipments.
- **Fake ratings** removed on production (9 products had seeded counts such as 4.3 stars / 52,000 reviews).
- **Checkout rules:** pincode serviceability, store-wide COD switch and per-pincode rules (fee, COD, delivery estimate) all enforced by the server and explained to customers.

GST tax invoices (new)

- Sequential numbers per financial year (**CF/2627/000001**), CGST + SGST within the seller's state, IGST otherwise, HSN per product, amount in words, reverse-charge line.
- Download from the website order page, the app order details and the admin order view; orders from before the GST change are reproduced exactly as they were charged.
- **Off until the owner enters the real GSTIN** and switches invoices on (the sample GSTIN in settings is rejected).

TAX INVOICE

Original for recipient

ChillFi

123, Tech Park, Whitefield, Bengaluru, Karnataka - 560066

GSTIN: 29AABCU9603R1ZM State: Karnataka (29)

+91 98765 43210 · help@chillifi.in

Invoice No.
CF/2627/000001

Invoice Date
25 Sept 2026

Order No.
CF4688283969

Order Date
25 Sept 2026

Place of Supply
Delhi (07)

Payment
PhonePe (Paid)

Bill To / Ship To
DLV-TEST Customer
DLV-TEST 12 Test Street
Connaught Place
New Delhi, Delhi - 110001
Phone: 9000000001

#	Item	HSN	Qty	Amount	Taxable	IGST 18%	Total
1	boAt Airdopes 141 TWS	—	1	₹1,178.82	₹999.00	₹179.82	₹1,178.82
				Taxable value		₹999.00	
				IGST @ 18%		₹179.82	
				Invoice total		₹1,178.82	

Amount in words: One Thousand One Hundred Seventy Eight Rupees and Eighty Two Paise Only

Tax payable on reverse charge: No

This is a computer-generated invoice and does not require a physical signature.

For ChillFi
Authorised Signatory

Sample invoice from local test data (sample seller details). This test order was placed before the switch to GST-inclusive prices, so GST appears on top — the invoice reproduces exactly what was charged. New orders show GST included in the price.

6. Delhivery shipping — staging end-to-end

Final run against real **staging-express.delhivery.com**: **48/48 checks passed**.

Area	Result
Shipment creation	Automatic — COD orders immediately, prepaid once paid; duplicate / parallel re-ship refused
AWB and pickup	AWB stored and shown in app, website and admin; pickup auto-booked; shipping label available
Tracking	Customer and admin tracking match; full scan history
Status events	In transit, at destination hub, out for delivery, failed attempt, RTO, delivered; out-of-order and duplicate events ignored
Delivered	Order marked Delivered, COD marked paid, cannot regress
Cancellation	Before pickup cancels the shipment; after pickup refused; RTO never shown as delivered
Notifications	Placed, shipment created, shipped, out for delivery, delivered, cancelled, returned — in-app and push, no duplicates (21 on device, 0 duplicates)
Webhook security	Bad/missing token › 401, invalid payload › 400
Errors	Rejections show an actionable reason, e.g. "Cash on Delivery isn't enabled on this Delhivery account"

Staging note: the Delhivery **staging** account has COD disabled, so prepaid orders were used for the lifecycle. Production stays on staging (no token) until the owner switches it — orders placed now are not booked with Delhivery automatically.

Proof — one order, same state everywhere (CF4688283969, AWB 86406910000302)

The image displays two side-by-side screenshots from the ChillFi project. The left screenshot shows the 'Order Details' screen in a mobile app. It features a top status bar with the time 10:51 and signal icons. Below the title 'Order Details', the order ID 'CF4688283969' is shown with a green 'Delivered' badge. The payment method is 'PhonePe', status is 'Paid', and date is '25/9/2026'. The tracking ID (AWB) is '86406910000302' and the shipment status is 'Delivered'. A section titled 'Items (1)' lists 'boAt Airdopes 141 TWS x 1' for ₹999. The subtotal is ₹999, delivery is FREE, GST is ₹180, and the total is ₹1179. At the bottom, there are buttons for 'Track Order' and 'Request Refund / Return'. The right screenshot shows the 'Orders' page in the admin panel. It has a top navigation bar with 'Search products...' and 'Admin User'. Below the title 'Orders', there are filters for 'All 139', 'Processing 52', 'Shipped 2', 'Delivered 27', and 'Cancelled 54'. A table lists orders, with the first row showing order ID 'CF4688283969', customer 'DELV-TEST Customer', product 'boAt Airdopes 141 TWS', quantity '1', amount '₹1,178.82', payment 'PhonePe', date '25 Sept 2026', status 'DELIVERED', and waybill '86406910000302'. The table indicates 'Showing 1-1 of 1 orders'.

Left: app order details (Delivered, Paid, AWB). Right: admin orders list (Delivered, AWB).

7. Admin › app / website synchronisation

Each change was made in the admin and observed live in the app (Android emulator) and on the website.

Admin change	Result in app / website
Banner created / deleted	Shown first on Home; removed when deleted
Coupon deleted	Offer card switched to the next real coupon
Price edited	New price (₹1,777) shown in search and product page
Product deactivated	Search: "No results"; wishlist: "No longer available"; product page: "Product unavailable"; cannot be added to cart
COD master switch	Payment screen toggles "Currently unavailable" / available, live, no restart
Maintenance mode	Maintenance screen with the admin's message; "Check Again" resumes; admin can still sign in on the website
Free-delivery threshold	Changed to ₹799 › product page, top bar and trust strips updated
Contact details	Changed phone/email › website contact, help and policy pages and app Help & Support updated
Push / admin notification	Delivered to the device (foreground and background) on the "Order updates" channel

8. Responsive and usability audit

- **Website:** 30 pages × 17 widths (320 › 1920 px), signed in, including account and tracking pages — **0 horizontal overflow, 0 JavaScript errors.**
- **Tap audit:** 2,755 interactive elements — none hidden or blocked.
- **Universal error handling:** every failure on app, website and admin shows a friendly dialog or inline state with retry — never a raw error or blank screen.
- **Honesty pass:** fake or placeholder content removed or labelled: fake ratings and stats, "CHILLFI Cash", a fake location-permission screen, dead buttons, mock screens with invented products, placeholder settings.
- **App polish:** bundled Poppins font (works offline), local-time dates, guest sign-in prompts, pinned maintenance "Check Again", correct notification channel and app name.

9. New features built

Feature	What it does	Status
GST tax invoices	Numbered invoices, CGST/SGST/IGST, HSN, PDF download on website/app/admin	Live · off until real GSTIN
Email notifications	Order emails to customers; new-order and low-stock alerts to the store; "Send test email"	Live · inactive until SMTP entered
SMS order updates	MSG91 transactional SMS for key order moments	Live · inactive until DLT template
Go-Live checklist	Admin page showing every launch item's live status with one-click "Fix"	Live
Payment safety	Abandoned-payment expiry, late-payment auto-refund, sandbox guard on production	Live
Contact from admin	Phone / email / WhatsApp edited in Store Info, used by app and website	Live
Admin security	OTP-only sign-in, sign-in log, 30-min idle sign-out, registration pause switch	Live
Admin alerts bell	Real counts: failed shipments, orders to ship, refunds, messages, low stock	Live
Store settings	COD switch, per-pincode rules, reviews switch, SEO tags, delivery days — all enforced	Live
Health endpoint	/api/health checks API + database for uptime monitors	Live
Nightly backups	Database dump at 02:30 IST, 7 daily + 6 monthly, verified	Live

10. Production deployment log (25 September 2026)

Every production action below was approved by the owner. Each deployment was preceded by a dry run and followed by health and smoke checks; each has a backup on the server.

#	Action	Result
1	Deploy all security, money and QA fixes (backend + website)	Healthy; exploit check: never used (22 orders)
2	Recalculate product ratings from real reviews	9 products corrected; no fake ratings remain
3	Deploy GST-inclusive pricing + contact details from admin	Charged total = displayed price
4	Deploy sandbox-payment guard	Online payment off until PhonePe is live (COD only)
5	Upgrade server Node 20 › 22.23.3; install pm2 auto-start on reboot	Both API processes on Node 22; auto-start enabled
6	Deploy invoices, email/SMS, auth hardening, alerts, SEO, health endpoint; add log rotation	Healthy; 19/22 orders got address snapshots
7	Install nightly database backup (systemd timer)	Backups verified: row counts match live for all key tables
8	Deploy admin Go-Live checklist	Live; reflects real production status

11. Production readiness today (Go-Live checklist)

Status as read from the live production server. The same checklist is in Admin › Settings › Go-Live, with a "Fix" button for each item.

Item	Status	Where to fix (admin)
Online payments live (PhonePe)	To do · Test mode — COD only	API Keys › Payment Gateway
Delhivery live shipping	To do · Staging mode	API Keys › Shipping
Cash on Delivery	Done · On (confirm with Delhivery)	Shipping › COD Available
App v1.0.3 + force update	To do · After Play Store release	Store Info › Force Update
GST tax invoices	To do · Sample GSTIN	Store Info
Real contact details	To do · Test values	Store Info
Order emails (SMTP)	To do · Not set up	API Keys › Email
SMS updates (optional)	To do · Not set up	API Keys › OTP / SMS
Nightly database backup	Done · Running, verified	Automatic
Uptime monitor	— Outside admin	uptimerobot.com › /api/health

Settings
Manage your store configuration

Go-Live

Go-Live Checklist
1 of 8 launch items done — checked live from your settings.

- Online payments live (PhonePe)**
Test (UAT) mode — fine for development
How: API Keys → Payment Gateway: enter live Merchant ID + Salt Key, then set Environment = PRODUCTION.
- Delhivery live shipping**
Test (staging) mode — orders are not booked with Delhivery for real
How: API Keys → Shipping: enter the production API token + exact pickup location name, then set Environment = production.
- Cash on Delivery**
ON — confirm COD is enabled on your live Delhivery account
- Customers on app v1.0.3+ (force update)**
Turn on after v1.0.3 is live on Google Play (older app shows GST on top)
How: Store Info → Force Update + Minimum App Version = 1.0.3, once v1.0.3 is live on Google Play.
- GST tax invoices**
GSTIN is still the sample value
How: Store Info: enter your real GSTIN, legal name and address, then turn on "Issue GST Tax Invoices".
- Real contact details**
Phone / address are still sample values
How: Store Info: set the real phone, support email (and WhatsApp) customers should use.
- Order emails (SMTP)**
Not set up — customers get in-app + push only
How: API Keys → Email (SMTP): enter your provider's SMTP details, then "Send test email".
- SMS order updates (MSG91)** OPTIONAL
Optional — needs a DLT-approved template
How: API Keys → OTP / SMS: MSG91 key + DLT template ID, then SMS order updates = on.
- Nightly database backup**
No backup found on this server
How: Runs automatically every night at 02:30 IST on the server.
- Uptime monitor (external)** OPTIONAL
Can't be checked from here — set up UptimeRobot on <https://chillfi.in/api/health>
How: Create a free UptimeRobot monitor for <https://chillfi.in/api/health> (keyword "ok").

Server: Node v26.0.0 · up 0 h · memory 118/7180 MB free · disk 30.7/494.3 GB free

Admin › Settings › Go-Live checklist.

12. Owner action list

Required before serving real customers

#	Action	Where
1	Enter live PhonePe Merchant ID + Salt Key, then set environment PRODUCTION. Then one real test order and refund.	Admin › API Keys › Payment Gateway
2	Enter live Delhivery API token + exact pickup location name, then set environment production (see QA/DELHIVERY_GO_LIVE.md).	Admin › API Keys › Shipping
3	Confirm with Delhivery that COD is enabled on the live account (otherwise switch COD off).	Admin › Shipping
4	Upload FinalApp/ChillFi-v1.0.3-build4-release.aab to Google Play; then turn on force update with minimum 1.0.3.	Play Console, then Admin › Store Info
5	Enter real GSTIN, legal name and address; switch on GST invoices.	Admin › Store Info

Recommended soon

#	Action	Where
6	Real support phone / email / WhatsApp (customers currently see test values).	Admin › Store Info
7	Uptime monitor on https://chillfi.in/api/health (free, 5 minutes).	uptimerobot.com
8	SMTP details for emails, then "Send test email"; optional MSG91 DLT template for SMS.	Admin › API Keys
9	Off-server backup copy: EBS snapshot policy, or an IAM role so backups can go to S3.	AWS console
10	Remove Firebase test phone numbers before public launch (anyone can sign in with +91 90000 00001 / 123456).	Ask the developer
11	One test on a real Android phone: login, payment, push.	Owner
12	Push the code to a private Git repository (currently only on the developer Mac and the server).	Owner approval

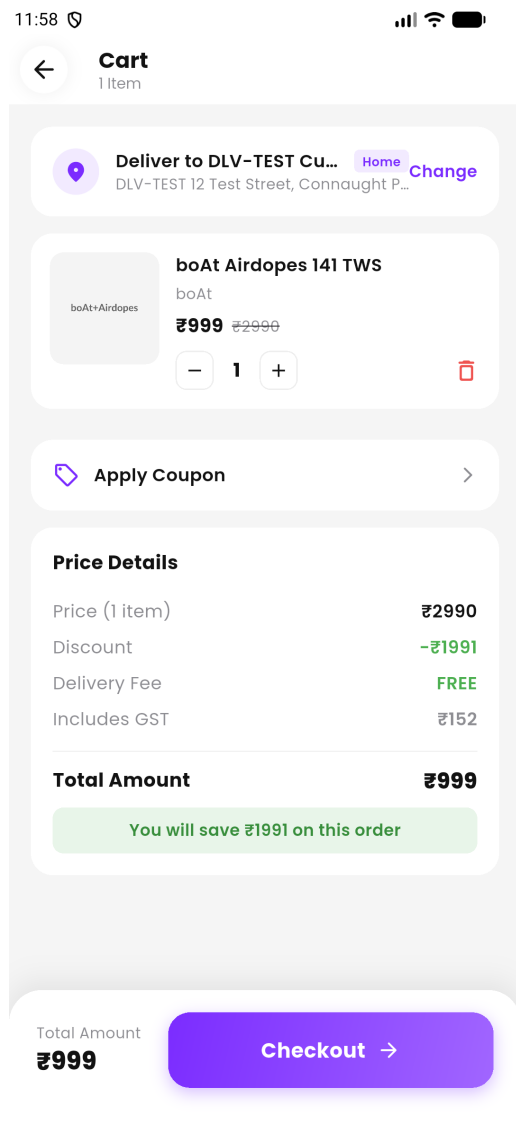
13. Operations: backups, monitoring, server

- **Server:** AWS EC2 (Amazon Linux 2023, ~1 GB RAM, 2 vCPU), Node 22.23.3, pm2 with 2 API processes, auto-start on reboot, log rotation (10 MB × 7, compressed), nginx with HTTPS.
- **Backups:** nightly at 02:30 IST › ~/db-backups (7 daily + 6 monthly), each checked readable; ~/bin/chillfi-restore-check.sh compares backup contents with live (read-only). Restore steps in QA/OPS_RUNBOOK.md.
- **Gap:** backups are on the same server — they protect against mistakes and corruption, not against losing the server. Add EBS snapshots or an S3 copy.
- **Monitoring:** https://chillfi.in/api/health returns 200 only when API and database respond (503 otherwise). An external monitor must be created by the owner.
- **Server size:** fine for launch. When traffic grows move to t3.small (2 GB) — first confirm 3.111.32.220 is an Elastic IP.
- **Runbooks:** QA/OPS_RUNBOOK.md (operations), QA/DELHIVERY_GO_LIVE.md (switching Delhivery to live).

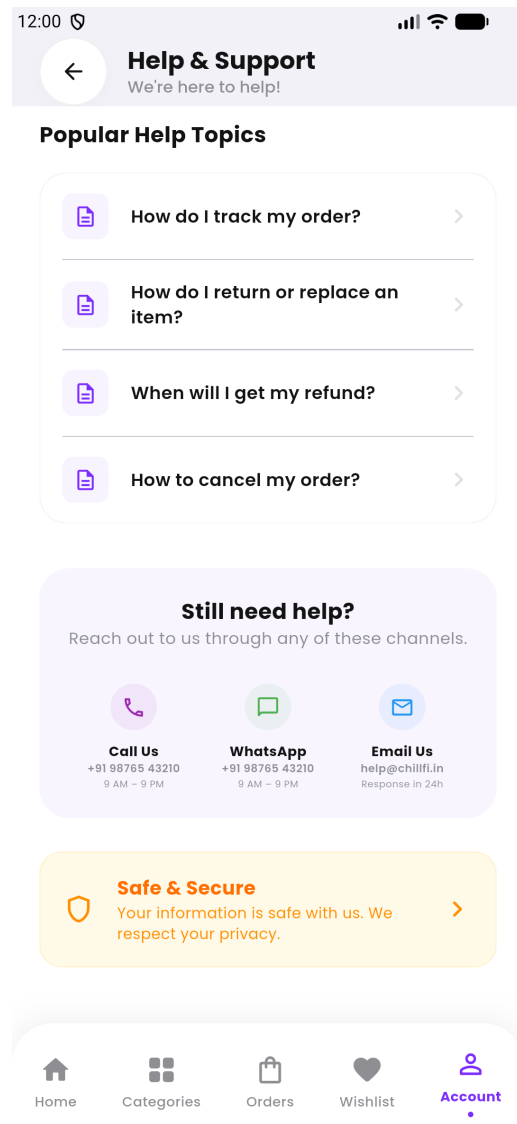
14. Remaining limitations

- iOS app not built or tested — all app testing was on Android.
- Image uploads not testable on the local setup (no Cloudinary keys); production has keys — try one upload in the live admin.
- Website OTP login checked by code and API only; its reCAPTCHA step must be checked once by hand.
- Not built: promotional emails (need unsubscribe/consent handling) and guest checkout (orders, tracking and invoices need an account).
- Old app v1.0.2 shows GST added on top until users update — resolved by force update after v1.0.3 is live.

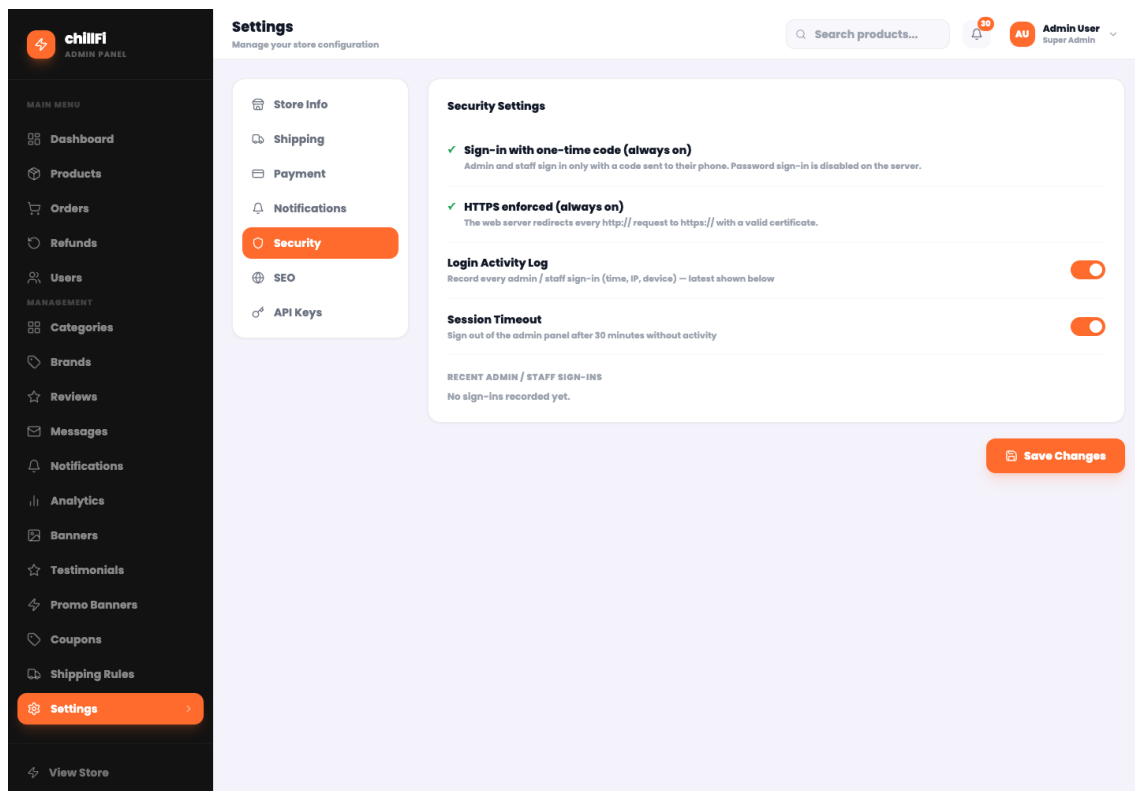
Appendix A — Screenshots



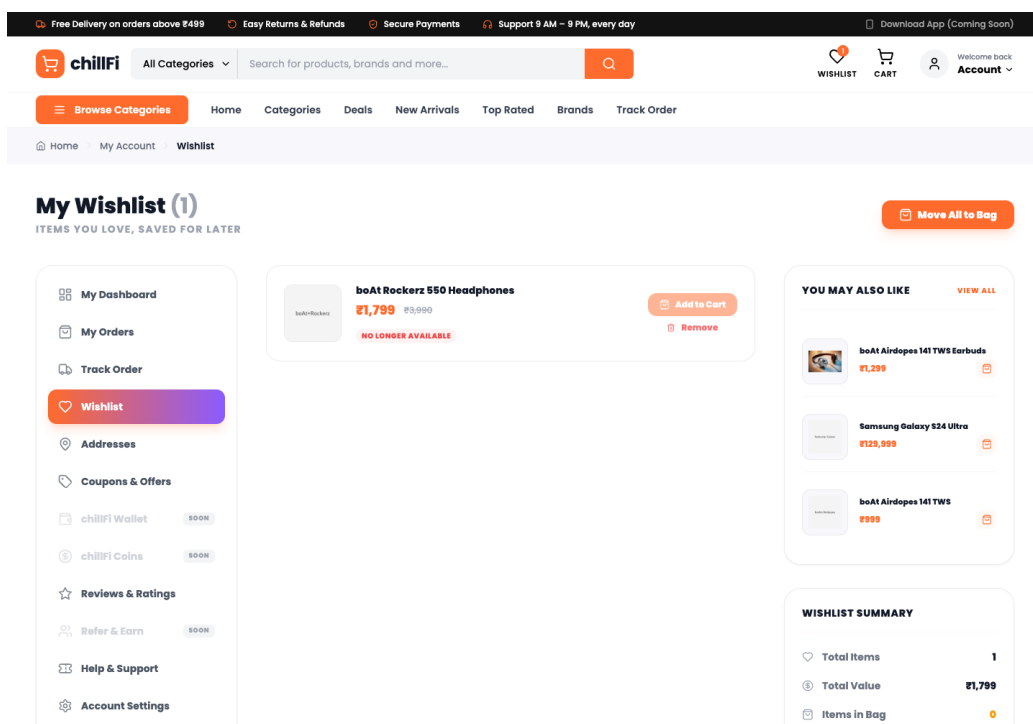
App cart — GST-inclusive total



App Help & Support — contact from admin



Admin › Settings › Security — only real controls remain.



Website wishlist — deactivated product shown as "No longer available".

Appendix B — Complete defect register

124 defects: 11 critical · 46 high · 41 medium · 26 low. All fixed and re-tested (one website content item fixed locally and in seed data; its production banner text is an admin edit).

ID	Area	Sev.	Defect	Fix
ADEF-A1	Admin	Critical	Products: brand/category never saved (names sent, ids expected); inactive products vanished from admin; delete wording false; weak validation	resolveRefs() name>id; /admin/products incl. inactive; honest Deactivate; server validation
ADEF-A5	Admin	Critical	CRITICAL: Refunds page called non-existent endpoints › admins never saw any refund request; no customer notification; refunded requests could be reopened	/admin/refund-requests; notifications; final state
ADEF-A9	Admin	Critical	Settings save response returned every stored credential in plain form (Delhivery/PhonePe secrets) to the browser	Filter credential keys from the response
ADEF-27	App	Critical	SECURITY: order API accepted expired / below-minimum / already-used coupons and silently ignored invalid ones; apply-coupon trusted client order_total; flat coupon could make total negative; inactive/OOS products orderable	createOrder re-validates coupon (exists, expiry, min order, per-user use), clamps discount, rejects unavailable items; apply-coupon uses server cart value
ADEF-29	App	Critical	PhonePe payment page never opened on Android 11+ (canLaunchUrl blocked by package visibility) while app claimed it did; Force-update 'Update' button same bug and pointed to wrong Play Store id (com.chillfi.app)	Manifest <queries> for https/http/upi/market/tel/mailto; launch directly with error dialog + retry; store link › com.ecom.chillfi; iOS guidance
ADEF-30	App	Critical	SECURITY: payment 'dev shortcuts' mark orders Paid without PhonePe when NODE_ENV≠production (incl. unauthenticated /payment/callback and /dev-success) — any non-prod or misconfigured server gives free orders	Single DEV_AUTOPAY flag requiring NODE_ENV=development AND PAYMENT_DEV_AUTOPAY=true; production verified NODE_ENV=production (safe)
ADEF-33	App	Critical	Cancelling a PAID order (customer or admin) created no refund; admin cancel didn't restore stock; admin could reopen Cancelled/Delivered orders; refund/return offered for unpaid cancelled orders	openAutoRefund on paid cancellations; admin cancel restores stock; terminal-state guard; refund rules in app + API
ADEF-41	App	Critical	About: fake version 2.5.0, invented stats (5M+ customers, 10M+ orders), Terms 'coming soon'; FORCE-UPDATE compared hardcoded 1.0.0 › could lock out up-to-date users; '24x7 support' vs real 9–9 hours (app + website)	package_info_plus real version for About + force update; stats removed; Terms linked; support hours consistent
ADEF-51	App	Critical	Cart API accepted negative/zero/fractional/huge quantities — negative line lowered order total and increased stock (pay ₹1,000 for a ₹5,000 item)	Integer ≥1 and ≤ stock in add/update; order refuses non-positive quantities
WDEF-17	Website	Critical	PRICING: cart always 'Free' delivery & total without GST; checkout offered ₹79 Express the server never charged; GST shown before coupon (server after) › displayed ≠ charged	Cart uses live settings; Express removed; GST after coupon; MRP breakdown; backend honours free_shipping_enabled

ID	Area	Sev.	Defect	Fix
WDEF-34	Website	Critical	Production ran PhonePe in sandbox mode: online checkout would fail for customers or a sandbox 'payment' could be accepted	Server refuses online orders/payments and ignores sandbox success when <code>NODE_ENV=production</code> and <code>PhonePe≠PRODUCTION</code> ; app-config <code>online_payment_available</code> ; app + web show 'Temporarily unavailable' and default to COD
ADEF-A12	Admin	High	Settings load failure showed defaults; Save would overwrite real config	Dialog + banner; Save disabled
ADEF-A2	Admin	High	Dashboard/analytics: revenue included cancelled paid orders; analytics counted unpaid orders; fake +100% growth; silent mock data when API failed; top products counted cancelled	Single <code>PAID_KEPT</code> definition; null % when no prior data; error banner; chronological months
ADEF-A22	Admin	High	Abandoned online payments kept orders 'Processing' forever (stock + coupon held); a late payment on a cancelled order sent 'Order confirmed' and opened no refund	<code>paymentExpiry</code> job (gateway-verified, never cancels on uncertainty) + late-payment auto-refund
ADEF-A24	Admin	High	No GST tax invoices for customers	Sequential FY invoice numbers, CGST/SGST vs IGST by place of supply, HSN per product, amount in words; website/app/admin download; off until a valid GSTIN is set; old (GST-on-top) orders reproduced exactly as charged
ADEF-A25	Admin	High	Orders didn't keep their delivery address — editing or deleting an address changed or erased it on past orders (and on a not-yet-shipped Delhivery booking)	<code>shipping_address</code> snapshot at order time; backfilled 145/154 (9 already lost earlier)
ADEF-A26	Admin	High	Password sign-in endpoint (unused by app/website) allowed single-factor admin login; password reset endpoints open	Password login/reset disabled (<code>ALLOW_PASSWORD_LOGIN</code> to re-enable); admin sign-in = phone OTP only
ADEF-A3	Admin	High	SECURITY: admin role defaulted to 'admin' when profile failed to load; role cached across logout/login in same tab; staff saw admin-only actions	No default role; cache keyed to token; staff restrictions
ADEF-A6	Admin	High	Users: fake 'Remove'; admin could block/demote self; missing status crashed (500)	Removed; self-protection; validation
ADEF-A7	Admin	High	Deactivated categories/brands disappeared from admin forever (admin list reused public active-only query)	Admin list includes inactive
ADEF-01	App	High	Onboarding One: Skip covered by hero layer and unusable	Skip moved last in Stack; Fast Delivery badge moved down so they don't overlap
ADEF-03	App	High	Leftover password UI in OTP-only app (Forgot Password link, reset flow, Sign Up password field that was discarded)	Removed Forgot Password entry and Sign Up password field; reset screens now unreachable (orphans)
ADEF-05	App	High	Maintenance: dead buttons, hardcoded 'May 18, 2025' downtime	Removed fake card/buttons; Check Again re-reads /app-config and resumes app
ADEF-07	App	High	Add-to-cart from listing/offers/deals/trending/new-arrivals/recommended gives no feedback; failures silent	Shared <code>addToCartWithFeedback()</code> : green snackbar on success, <code>AppErrorDialog</code> on failure; wired into 6 screens + details/wishlist/deals/recently-viewed

ID	Area	Sev.	Defect	Fix
ADEF-09	App	High	Raw technical/Firebase/Dio text could reach users in snackbars	AppError mapper + Dio interceptor friendly message + AppErrorDialog; firebaseFriendly() code map; voice error text
ADEF-15	App	High	Home banners ignore admin link (always open all products)	openAppLink() router for /product, /offers, /categories, /products?category=, external URLs
ADEF-17	App	High	Home advertises coupon CHILL10 which does not exist	Offer card shows best real active coupon from /cart/coupons, falls back to Today's Deals
ADEF-18	App	High	Fake ratings/review counts (e.g. 4.3 / 52,000 reviews with 0 real reviews) shown on app & website	scripts/recalc-ratings.js --apply on production (owner-approved): 9 products corrected
ADEF-19	App	High	Category counts ≠ listing (Audio 8 vs 7); Low Stock products hidden from listings; OOS products not marked	Listing shows all non-inactive; carousels Active+Low Stock; OOS overlay + disabled purchase on card and details
ADEF-22	App	High	Offline: logged-in users shown Welcome as if logged out; Home/Categories/Listing spin forever or say 'not found'	Session kept offline with cached profile (only 401/403 logs out); AppState + Try again on Home, Categories, Listing
ADEF-23	App	High	Listing: sort/brand filter only applied to loaded page; Filter button fake; in-page search dead; next page dropped search; 'Popular' sort fake	Server-side sort/brand/price/search on every page; price filter sheet; 'Newest' label; total count from server
ADEF-24	App	High	Product details: dead share button, dead AR button, decorative chevrons, false EMI/Bank/Exchange offers	Share via share_plus; AR/chevrons removed; offers replaced by true payment/return info
ADEF-25	App	High	Reviews: fake 'Verified Buyer'/'Purchased on CHILLFI' badges on every review, fake 'Verified Purchases' summary (any user can review), dead star filters, fake sort, dead helpful buttons, dead Add to Cart/Buy Now, chip overflow	Backend auto-verifies reviews from delivered orders + verified count; badge only when is_verified; server star filter; honest sort label; working bottom actions
ADEF-28	App	High	Addresses accepted invalid phone/pincode (e.g. 12345 / 11000) in app and API; no validation feedback; delete without confirmation	Backend validateAddress (create/update, phone normalised); shared app validator + digit filters + inline error; delete confirmation
ADEF-32	App	High	Bottom nav replaced the whole stack: Orders back arrow › blank screen; system Back on any tab exits app; Orders tab had no bottom nav	Home kept at base, tabs pushed on top; Orders asTab shows nav; maybePop
ADEF-37	App	High	PRIVACY: after logout, guest still sees previous user's address & cart badge; guest profile shows fake 'ChillFi User'; Login back arrow › blank screen after logout	reset() on Cart/Wishlist providers at logout; guest sign-in view; Welcome under Login
ADEF-38	App	High	Invalid email ('bad-email') saved to profile (app + API); duplicate email gave generic error	App + API validation; duplicate-email check
ADEF-39	App	High	Notification toggles had no effect (backend read 'orderUpdates', app saved per-stage keys)	Per-stage mapping in notifyUser

ID	Area	Sev.	Defect	Fix
ADEF-44	App	High	Discovery screens (Brands/Offer/Flash/New/Trending/Recommended): hardcoded fake category chips (Fashion/Beauty/Home) that didn't filter, fake countdown '02d 45h', fake bank/EMI/exchange offers, fake 'Notify me', dead 'View All'/'Shop Now', wrong nav tab highlighted, listing header count mismatch (22 vs 20)	Chips from real categories + filtering; fakes removed; CTA wired; Home highlighted; category_name added to curated/home APIs; totals from server
ADEF-46	App	High	App checkout accepted undeliverable pincodes; COD offered where unavailable	Provider checkServiceability; Proceed blocked; COD disabled + auto-switch to PhonePe
ADEF-57	App	High	Any failed token refresh (offline, rate limit, server error) signed the user out; parallel 401s refreshed twice with a rotating token and signed the user out	Single-flight refresh; sign out only on 400/401/403; transient 'server busy'; backend 401 only for invalid tokens
WDEF-01	Website	High	Header overflows at 768–820px on every page (search bar could not shrink; account labels too wide)	min-w-0 on search; account labels from lg; category selector lg+
WDEF-03	Website	High	/account overflowed 768–1280px	min-w-0, stats row from xl, 6-col grid from 2xl
WDEF-04	Website	High	/checkout and /categories overflowed at 1024px	min-w-0, 340px summary at lg, responsive padding
WDEF-05	Website	High	Phone: cart item name squeezed to 1 letter; search button clipped; hero arrows covered subtitle; order tracker labels merged	Wrapped cart row, min-w-0 search, arrows md+, compact tracker labels
WDEF-06	Website	High	Phone/tablet: no product filters, no account navigation; card actions hover-only	Filter drawer + Filters button; account menu strip; actions visible below lg
WDEF-07	Website	High	Invisible decorative elements blocked clicks (listing Sort/Filters row); footer link under Premium banner; order pagination under banner	relative + pointer-events-none on blobs; removed h-full; compact pagination
WDEF-09	Website	High	Website shows 'Failed to fetch' / JSON parse errors / backend internals	api.ts ApiError + friendlyError normalization; global ErrorDialogHost + showErrorDialog in contact, checkout, addresses, profile, tracking
WDEF-10	Website	High	Offers page: invented bank offers with HDFC/ICICI/SBI/Kotak logos, fake tab counts, fake countdown, fake 'chillFi Premium', '80% OFF' claim, dead buttons	Removed bank offers/tabs/premium; hero honest with working Shop Now; sidebar links to real listings; coupon wording fixed
WDEF-12	Website	High	Contact details inconsistent/placeholder: website +91 98765 43210 & '123 Green Park Society, Indiranagar, Bengaluru' vs app +91 90562 24993	Contact phone/email/WhatsApp now come from Admin › Settings › Store Info (app + website); test values kept per owner
WDEF-14	Website	High	Fake flash-sale countdown (2h45m reset every load); hardcoded 'Verified Buyer' on testimonials	Timer only with real end date; label removed
WDEF-15	Website	High	~25 dead/fake controls: premium banner, refer & earn, wallet/coins, fake bank offers, fake map/address, support search, FAQ without answers, share wishlist, buy again, invoices, newsletter fake success, invented About stats	Wired to real pages or removed (helper agent + review)

ID	Area	Sev.	Defect	Fix
WDEF-20	Website	High	Shipping Policy promised pincode serviceability check at checkout — none existed (orders to undeliverable pincodes accepted, COD offered where unavailable); summary failure = endless spinner; policy named unused 'Shiprocket'	GET /api/shipping/pincode/:pin (cached, rate-limited, Delhivery); web + app checkout block/disable COD; createOrder guard (only definitive 'no' blocks); retry state; policy text
WDEF-23	Website	High	Two wishlists: header/cards used browser-local list, PDP & app used server › badge wrong, app wishlist invisible on web; logout left previous user's cart/wishlist in browser	Store mirrors server wishlist when logged in (refresh after PDP toggle); logout clears cart+wishlist
WDEF-29	Website	High	Website signed customers out on any refresh failure (429/5xx/offline) and on concurrent 401s (token rotation race)	Single-flight refresh, tri-state result
WDEF-31	Website	High	During maintenance, signed-out admins were redirected to /login which was itself behind the maintenance page — admin could not sign in to turn it off	/login exempt
WDEF-33	Website	High	GST was added on top of displayed prices; owner chose GST-inclusive pricing	Backend total = items - coupon + delivery; GST reported as included (tax_amount) for invoices; app/web show 'Includes GST'; Terms updated; older orders labelled by formula
ADEF-A10	Admin	Medium	Shipping-rule COD / ETA fields saved but never enforced	checkoutServiceability merges rule COD + eta_days; order guard
ADEF-A11	Admin	Medium	~20 Settings controls had no effect, incl. store-wide COD switch	COD + Reviews switches wired; others disabled with 'Not active yet'; Payment tab explains PhonePe
ADEF-A13	Admin	Medium	Coupons: no validation (missing code › 500, 150% allowed); expiry/limit could not be cleared	validateCoupon; clearable fields
ADEF-A15	Admin	Medium	Image upload ignored admin-saved Cloudinary keys; failures showed generic 500; non-image › 500	Settings-first config, clear 503/400 messages
ADEF-A19	Admin	Medium	Admin load failures silently showed empty lists; errors used success-styled toasts	Universal error dialog across 11 admin pages
ADEF-A20	Admin	Medium	Analytics/Refunds: a slower earlier response could overwrite the newly selected period/filter (e.g. 1 Year showed 7-day zeros)	Ignore superseded responses; errors via dialog
ADEF-A23	Admin	Medium	Delhivery rejection showed as generic 'Something went wrong' toast for 3s (raw text ›180 chars / technical)	explainRejection() concise actionable text; error dialog
ADEF-A27	Admin	Medium	Remaining 'Not active yet' settings: registration switch, login activity log, session timeout, SEO, max delivery days did nothing; guest checkout / express / 2FA / force-HTTPS toggles were misleading	Implemented registration pause, staff sign-in log, 30-min admin idle sign-out, SEO title/meta, delivery-days text; removed unsupported toggles; 2FA + HTTPS shown as always-on facts
ADEF-A28	Admin	Medium	No email/SMS notifications; admin had no new-order or low-stock alerts	SMTP mailer (customer order emails, new-order + low-stock alerts, test button) and MSG91 SMS order updates; inactive until configured
ADEF-A4	Admin	Medium	Orders: Qty always 1; only 200 newest loaded silently	item_count/line_count; limit 1000 + notice

ID	Area	Sev.	Defect	Fix
ADEF-02	App	Medium	Login: dead language selector; phone field accepts letters and >10 digits	Selector and fake +91 dropdown arrows removed; digitsOnly + 10-digit limit on Login & Sign Up; 6-9 start rule
ADEF-04	App	Medium	Sign Up doesn't validate name/phone/email	Name ≥2 chars, Indian mobile regex, email regex when provided
ADEF-06	App	Medium	Home header never shows delivery address	Home loads addresses for logged-in users; header tappable; flexible with ellipsis
ADEF-08	App	Medium	Similar products card says 'Added to cart' even when the add fails	Uses addToCartWithFeedback
ADEF-10	App	Medium	Home header overflowed with longer address label (RIGHT OVERFLOWED stripe)	Flexible + ellipsis
ADEF-11	App	Medium	White logo on white background invisible (Home header, Maintenance, Login placeholder)	New assets/images/logo_color.png (orange, transparent); login placeholder removed
ADEF-12	App	Medium	Address picker footer hardcoded 'Deliver to 226010', fake '24-48 hours', dead 'Change Pincode'	DeliveryInfoCard shows selected city/pincode; dead button removed
ADEF-13	App	Medium	Home cart badge missing until Cart visited	Home init loads cart for logged-in users
ADEF-14	App	Medium	Voice search: tiny mic target on Home, RIGHT OVERFLOW on voice screen, invisible logo, unclear denied-permission state	48dp target; flexible waves + max-width status; colour logo; clear permission message
ADEF-26	App	Medium	Price breakdown didn't add up (listed discounted price then subtracted discount again); '1 Items'; '₹1499.00'	First row = MRP total on Cart/Checkout/Payment; grammar; rounded ₹ in message
ADEF-35	App	Medium	Wishlist Clear All: no confirmation, list mutated while iterating	Confirm dialog; iterate a copy
ADEF-36	App	Medium	Saved Addresses, Recently Viewed, Help & Support not reachable from profile	Added to profile menu
ADEF-40	App	Medium	Help & Support: dead search box, 'My Tickets'/'View All' coming-soon controls, Account tile just closed screen, FAQs didn't answer	Removed dead controls; FAQ answer sheets; correct destinations
ADEF-45	App	Medium	Cancel screen: dead Track/Contact buttons; refund card claimed '3-5 days' (policy 5-7) and showed for unpaid orders	Buttons wired; card only when paid online; 5-7 days
ADEF-47	App	Medium	Home welcome card showed a fake 'CHILLFI Cash' balance (hardcoded 0) and 'earn rewards'	Card now opens My Orders (signed in) or Sign in (guest)
ADEF-48	App	Medium	Order/wishlist/tracking dates shown in UTC — orders placed 00:00-05:30 IST showed the previous day	toLocal() in models + tracking
ADEF-49	App	Medium	COD availability not refreshed on payment screen; store-wide COD off said 'Not available for this pincode'	Re-check on payment open; backend cod_reason; wording
ADEF-52	App	Medium	Deactivated products still opened and could be added to cart from wishlist/old links; wishlist said 'In Stock'; product error blamed the connection; repeated identical search showed stale results	404 'no longer available', cart refuses Inactive, app/web unavailable states, search always refetches

ID	Area	Sev.	Defect	Fix
ADEF-53	App	Medium	Fonts (Poppins via google_fonts) are downloaded at runtime from fonts.gstatic.com — offline/first launch falls back to system font and logs unhandled exceptions	Poppins (SIL OFL) bundled in assets/fonts, runtime fetching off, licence registered
ADEF-54	App	Medium	Permission onboarding was fake: 'Allow Location Access' requested nothing (no location use) and 'Allow Notifications' only navigated; real notification prompt fired at cold start without context	Removed location step; notification permission requested on Allow + push token registered; no cold-start prompt
ADEF-58	App	Medium	App Checkout/Payment totals with a coupon kept GST on the full subtotal (shown ≠ charged)	Inclusive model: total = subtotal - coupon + delivery
WDEF-02	Website	Medium	Search bar 'All Categories' control was dead (no handler)	Real category select; searches within category via /products?category=&q=
WDEF-08	Website	Medium	Address form & contact info forced 2 columns on phones	grid-cols-1 sm:grid-cols-2
WDEF-11	Website	Medium	Website claims '24/7 support' in 9 places while contact hours are 9 AM–9 PM	Copy updated
WDEF-16	Website	Medium	Registration accepted invalid email; login panel claimed member-only deals / faster delivery	Web + API validation; honest copy
WDEF-18	Website	Medium	Order success claimed 'Payment Confirmed' for COD, SMS tracking link and '3–5 days' (none exist)	Pay on Delivery vs Paid; honest delivery text
WDEF-19	Website	Medium	Orders search only searched current page; 'Delivered on —' always; fake 'Download Invoices'; 'Support Tickets' (no system)	Server search param; real delivered/expected dates; removed/renamed
WDEF-22	Website	Medium	Product listing showed 'No products found' when the API failed/offline	Error state + Try again
WDEF-24	Website	Medium	Checkout 'Add address' silently did nothing on missing/invalid fields and swallowed API errors	Inline validation + friendly API error
WDEF-27	Website	Medium	Checkout allowed COD when COD was off store-wide but courier serviceability unknown (order then refused)	Disable whenever cod===false; reason-specific badge
WDEF-35	Website	Medium	Free-delivery threshold and delivery time hardcoded (₹499, 3–5 days) in 7 places; wrong if admin changes shipping settings	All read Admin › Settings (threshold, fee, free on/off, max delivery days)
ADEF-A14	Admin	Low	Shipping rules: no validation; free-above could not be cleared	validateShippingRule; clearable
ADEF-A16	Admin	Low	Admin bell was static ('No new notifications')	/admin/alerts with real counts + links
ADEF-A17	Admin	Low	Header search did nothing when Products page already open	Sync from searchParams
ADEF-A18	Admin	Low	Support staff could open admin-only pages (403-broken) and saw Settings in menu	Staff path allowlist + menu
ADEF-A21	Admin	Low	A QA test product from an interrupted run was left Active on the (local) storefront	Deactivated; suites now self-seed and clean up
ADEF-A8	Admin	Low	Analytics: placeholder 'Top Regions'; load errors silently showed empty page	Real top regions; error banner

ID	Area	Sev.	Defect	Fix
ADEF-16	App	Low	Home tiles misaligned; Fast Delivery tile hardcoded ₹499; dead QR scanner icons on Home and listing search	Top alignment; threshold from /app-config; QR icons removed
ADEF-20	App	Low	'Best Seller' badge shown for any admin-featured product	Renamed to 'Featured'
ADEF-31	App	Low	Auto-cancel after failed payment initiation sends 'Order cancelled' push for an order the customer never saw	No "Order cancelled" notification for unpaid online orders (never confirmed)
ADEF-34	App	Low	Cancel screen Support button dead; tracking title truncated	Support › Help & Support; title 'Track Order'
ADEF-42	App	Low	Guest Orders/Wishlist tabs show empty lists instead of a login prompt	GuestPrompt with Login / Sign up on Orders and Wishlist
ADEF-43	App	Low	Help contact: tel link without +91 country code, dead 'Connect FB & Instagram'	tel:+91..., error dialog fallback, Connect removed
ADEF-50	App	Low	Maintenance 'Check Again' button below the fold on standard phones	Pinned above footer
ADEF-55	App	Low	Avatar upload failure showed admin setup instructions to customers	Customer-safe 503 message
ADEF-56	App	Low	Order success 'View My Orders' pushed with a popped screen's context (possible crash); dead QuickActionsGrid with unwired 'Download Invoice'	Captured navigator; removed dead widgets
ADEF-59	App	Low	Dead code with fake data: mock profile/order widgets (rahul.sharma@example.com, Lucknow address), unreachable Forgot Password screen, OTP screen default fake phone	Removed; phoneNumber required
ADEF-60	App	Low	Pushes landed in Android's fallback 'Miscellaneous' channel; launcher label was lowercase 'chillfi'	High-importance 'Order updates' channel + FCM default channel meta-data; label 'Chillfi'
ADEF-61	App	Low	Filtered order tabs showed 'No orders yet / Start shopping' even when the customer has other orders	Tab-specific empty message
ADEF-62	App	Low	Dead mock screens with fake products (EmptyCartScreen: Puma sneakers, Lavie bag) and unused website CartTable with fake items	Removed
WDEF-13	Website	Low	Header 'Brands' ignored (showed all products); 'Best Sellers' actually rating sort	Brands › brands section; renamed Top Rated
WDEF-21	Website	Low	Breadcrumbs used <a href> (full page reload); legal links on Login/Contact/Delete forms navigated away losing typed data; stale © years	Router Links; legal links open in new tab; dynamic year
WDEF-25	Website	Low	Promo banner copy says 'Use code FREESHIP' but no such coupon exists (free delivery ≥₹499 is automatic)	Seed + local banner: "Applied automatically on orders over ₹499"; production banner text is content-owner action
WDEF-26	Website	Low	Order card payment status always green (Pending/Failed looked successful); '(1 Item)' hardcoded	Colour by status; 'Not completed' for Failed; real item count
WDEF-28	Website	Low	Wishlist showed deactivated products as In Stock with Add to Cart	'No longer available' + disabled
WDEF-30	Website	Low	Listing showed 'Showing 0-0 of 0 products' next to a load error	Hidden on error

ID	Area	Sev.	Defect	Fix
WDEF-32	Website	Low	Account menu items were buttons, not links (no open-in-new-tab, weaker ally)	Links with aria-current; actions stay buttons